

CYBER SECURE SOLUTIONS

Gestion d'une attaque avancée par ransomware

Type: plan_reponse_ransomware

Date: 3/31/2025

Référence: Gestion de crise cyber

Destinataire: Eddy

****Document Technique : Plan de Réponse à une Attaque Ransomware****

****Domaine : Gestion de crise cyber****

****Scénario : Gestion d'une attaque avancée par ransomware****

****Niveau de difficulté : Expert****

****Destinataire : Eddy****

****Contact : Lorenzo Bertola (Responsable Sécurité Informatique)****

****Contexte et Description de l'Incident****

Le système d'information de votre organisation a été compromis par un ransomware de type avancé, identifié comme une variante de la famille "BlackBasta". Les premiers signes de l'attaque ont été détectés il y a 6 heures, lorsque plusieurs utilisateurs ont signalé l'impossibilité d'accéder à des fichiers critiques. Une note de rançon a été découverte sur plusieurs postes utilisateurs, exigeant un paiement en crypto-monnaie (Bitcoin).

Selon les premières analyses :

- La propagation semble avoir exploité des vulnérabilités non corrigées dans les services RDP (Remote Desktop Protocol) et/ou des informations d'identification compromises.
- Les fichiers sur plusieurs serveurs stratégiques (nommés ****SRV-OPS01****, ****SRV-DB02****, et ****SRV-ARCHIVE****) ont été chiffrés avec un algorithme de chiffrement RSA-4096.
- Une communication réseau inhabituelle a été observée vers un serveur externe localisé dans une zone géographique à haut risque (IP : 192.168.33.207). Ce serveur semble être utilisé comme centre de contrôle pour l'attaquant.

****Impact Identifié****

1. ****Opérationnel : ****

- Services critiques indisponibles (ERP, CRM).
- Accès à la base de données principale bloqué.
- Perte temporaire de capacité de traitement des commandes clients.

2. ****Sécurité : ****

- Risque de fuite de données sensibles (documents internes, informations clients) via exfiltration vers des serveurs externes.

- Possibilité de double extorsion : demande de rançon pour déchiffrement et menace de publication des données.

3. ****Réputation et Financier****

- Menace immédiate pour la réputation auprès des partenaires et clients.
- Coût potentiel élevé en cas de réponse non adaptée (ransom + reconstruction du SI).

****Indicateurs Techniques****

Les éléments suivants ont été relevés par l'équipe SOC (Security Operations Center) :

- ****Hash MD5 de la charge malveillante**** : `d41d8cd98f00b204e9800998ecf8427e``
- ****Nom du fichier initial soupçonné**** : `invoice_update_2023.exe``
- ****URL de communication vers l'extérieur**** : `hxxp://malicious-server[.]com/command``
- ****Processus malveillant actif**** : `encryptor_service.exe`` exécuté avec des privilèges élevés.
- ****Port utilisé pour la communication externe**** : TCP 443.

****Ressources Disponibles****

- ****Backup**** : Dernière sauvegarde complète des serveurs datant de J-7.
- ****Équipe technique**** : 3 ingénieurs systèmes + 1 analyste SOC.
- ****Budget d'urgence**** : Non déterminé. À valider auprès du responsable financier.
- ****Accès à outils spécialisés**** : Endpoint Detection and Response (EDR), analyse réseau via SIEM (Splunk).

****Questions Clés à Traiter****

1. Quelles sont les étapes prioritaires à prendre pour isoler les systèmes compromis tout en préservant les preuves pour une analyse forensic ?
2. Comment identifier si l'attaque est encore active et si des mécanismes de "backdoor" ou de persistance sont en place ?
3. Quelle stratégie de communication interne et externe doit être mise en œuvre pour minimiser les dommages à la réputation ?
4. La sauvegarde disponible est-elle exploitable pour une restauration sécurisée du SI ? Si non, quelles alternatives pourraient être envisagées ?
5. Existe-t-il des obligations légales ou réglementaires en matière de notification de l'incident à des tiers ou autorités compétentes ?

****Historique et Références Utiles****

- ****Incident similaire**** : En 2022, une attaque par ransomware de la même famille a impacté une entreprise du secteur logistique, avec des pertes estimées à 2,5 millions d'euros.
- ****Documentation technique sur BlackBasta****
- Rapport de Threat Intelligence par Mandiant (2022).
- Analyse avancée des vecteurs d'attaque RDP par SANS Institute.

****Note Importante :****

Aucune action ne doit être entreprise avant validation par Lorenzo Bertola. Priorité à la coordination et au suivi du protocole de gestion de crise.

Fin du document.

